bakery-example.com

Audit de sécurité passif par Loïc Tellier · 27/10/2026 · note globale = domaine le plus faible

Exposition élevée : des corrections prioritaires sont nécessaires.

Global	Site web	Certificat & TLS	Email	Domaine & DNS
F	**F**	**B**	**C**	**C-**
domaine le plus faible	15/100 · barème Mozilla HTTP Observatory	70/100 · barème du projet (RFC 8996, 9325, validité du certificat)	55/100 · barème du projet (RFC 7208, 7489, 6376, 8461)	45/100 · barème du projet (RFC 4033, 8659, 9083, 9162)

2 critique · 14 à améliorer · 10 conforme · 11 info

Synthèse pour la direction

Principaux risques

- Un sous-domaine oublié peut être détourné pour publier du contenu au nom de l'entreprise. (Impact fort)
- Des logiciels obsolètes sur le site ont des failles connues que les attaquants exploitent automatiquement. (Impact fort)
- Les données des visiteurs (formulaires, identifiants) peuvent être interceptées, par exemple sur un Wi-Fi public. (Impact fort)

Effort 9 correction(s) rapide(s) (moins de 30 min chacune), 6 de quelques heures, 1 chantier(s) demandant un développeur ou un prestataire.
Les seules corrections rapides feraient passer la note globale de F à C.

Actions prioritaires

1. **Sous-domaines oubliés (journaux CT)** (Critique · Impact fort · Correction rapide (moins de 30 min))
   Supprimez ces enregistrements DNS dès maintenant, ou recréez la ressource chez le fournisseur avant que quelqu'un d'autre ne le fasse.
2. **Versions de TLS acceptées** (À améliorer · Impact fort · Correction rapide (moins de 30 min))
   Désactivez TLS 1.0 et 1.1 et n'autorisez que TLS 1.2 et 1.3 (les navigateurs actuels n'utilisent plus les anciennes versions).
3. **Redirection HTTP vers HTTPS** (À améliorer · Impact fort · Correction rapide (moins de 30 min))
   Mettez en place une redirection permanente (301) de HTTP vers HTTPS.
4. **HSTS** (À améliorer · Impact fort · Correction rapide (moins de 30 min))
   Ajoutez « Strict-Transport-Security: max-age=31536000; includeSubDomains ».
5. **Protection contre le clickjacking** (À améliorer · Impact fort · Correction rapide (moins de 30 min))
   Ajoutez « X-Frame-Options: SAMEORIGIN » ou « frame-ancestors 'self' » dans la CSP.
6. **Logiciel : PHP** (Critique · Impact fort · Quelques heures)
   Passez PHP à une version maintenue (testez d'abord sur une copie du site) et masquez le numéro de version.
7. **SPF (expéditeurs autorisés)** (À améliorer · Impact fort · Quelques heures)
   Passez à « ~all », puis à « -all » une fois vos expéditeurs listés.
8. **DMARC (politique anti-usurpation)** (À améliorer · Impact fort · Quelques heures)
   Après quelques semaines d'analyse des rapports, passez à « quarantine », puis à « reject ».
9. **Content-Security-Policy** (À améliorer · Impact fort · Chantier (développeur ou prestataire))
   Définissez une CSP adaptée au site, en commençant en mode « Report-Only ».
10. **Certificat HTTPS** (À améliorer · Impact moyen · Correction rapide (moins de 30 min))
    Vérifiez que le renouvellement automatique est en place.

11. **DNSSEC** (À améliorer · Impact moyen · Quelques heures)
    Activez DNSSEC chez votre hébergeur DNS, puis publiez l'enregistrement DS chez votre registrar (souvent une simple option dans son interface).
12. **CAA (autorités de certification autorisées)** (À améliorer · Impact faible · Correction rapide (moins de 30 min))
    Publiez un enregistrement CAA qui nomme l'autorité que vous utilisez, par exemple 0 issue "letsencrypt.org".
13. **Verrou de transfert** (À améliorer · Impact faible · Correction rapide (moins de 30 min))
    Activez le verrou de transfert (souvent appelé « registrar lock ») chez votre registrar.
14. **Versions des logiciels affichées** (À améliorer · Impact faible · Correction rapide (moins de 30 min))
    Masquez les numéros de version dans la configuration du serveur.
15. **MTA-STS (livraison chiffrée des emails)** (À améliorer · Impact faible · Quelques heures)
    Publiez une politique MTA-STS (d'abord en mode « testing »), ou activez-la dans votre service de messagerie.
16. **Traceurs avant consentement** (À améliorer · Impact faible · Quelques heures)
    Ne chargez ces services qu'après l'accord du visiteur, via la bannière de consentement (ou un gestionnaire de balises en mode consentement) ; la mesure d'audience peut être exemptée aux conditions de la CNIL.

Sécurité du site web

Critique

Logiciel : PHP — non noté

PHP 7.4.3 ne reçoit plus de correctifs de sécurité depuis le 28/11/2022 : toutes les failles découvertes depuis restent ouvertes, et les attaquants recherchent ces versions automatiquement.

> Passez PHP à une version maintenue (testez d'abord sur une copie du site) et masquez le numéro de version.

Source : endoflife.date (dates de fin de support des versions de logiciels) — Voir aussi : Guide CNIL de la sécurité des données personnelles (2024) : sécuriser les sites web

---

À améliorer

Content-Security-Policy — -25 pts

Absent : aucune limite sur les scripts que la page peut charger (protection contre les injections XSS).

> Définissez une CSP adaptée au site, en commençant en mode « Report-Only ».

Sur Apache :

```
Header always set Content-Security-Policy-Report-Only "default-src 'self'; object-src 'none'; frame-ancestors 'self'"
```

Source : W3C Content Security Policy niveau 3 — Voir aussi : Guide ANSSI site web PA-009 v2.0 (2021), R14, R15, R16

À améliorer

Redirection HTTP vers HTTPS — -20 pts

Le site reste accessible en HTTP non chiffré, sans redirection.

> Mettez en place une redirection permanente (301) de HTTP vers HTTPS.

Sur Apache (.htaccess) :

```
RewriteEngine On
RewriteCond %{HTTPS} off
RewriteRule ^ https://%{HTTP_HOST}%{REQUEST_URI} [L,R=301]
```

Source : Guide TLS de MDN : redirection HTTP — Voir aussi : Guide ANSSI site web PA-009 v2.0 (2021), R1 · Guide CNIL de la sécurité des données personnelles (2024) : sécuriser les sites web

---

À améliorer

HSTS — -20 pts

Absent : le navigateur n'est pas obligé d'utiliser HTTPS lors des visites suivantes.

> Ajoutez « Strict-Transport-Security: max-age=31536000; includeSubDomains ».

Sur Apache :

```
Header always set Strict-Transport-Security "max-age=31536000; includeSubDomains"
```

Source : RFC 6797 (HTTP Strict Transport Security) — Voir aussi : Guide ANSSI site web PA-009 v2.0 (2021), R2

À améliorer

Protection contre le clickjacking — -20 pts

Le site peut être affiché dans un cadre sur un autre site (risque de clickjacking).

> Ajoutez « X-Frame-Options: SAMEORIGIN » ou « frame-ancestors 'self' » dans la CSP.

Sur Apache :

```
Header always set X-Frame-Options "SAMEORIGIN"
```

Source : RFC 7034 (X-Frame-Options) — Voir aussi : Guide ANSSI site web PA-009 v2.0 (2021), R17, R18

À améliorer	**Versions des logiciels affichées**
	Le serveur annonce ses versions (Server: Apache/2.4.41 (Ubuntu); X-Powered-By: PHP/7.4.3), ce qui aide un attaquant à cibler des failles connues.
	> Masquez les numéros de version dans la configuration du serveur.
	Sur Apache (configuration principale ; pour PHP, expose_php = Off dans php.ini) :
	`ServerTokens Prod`
	`ServerSignature Off`
	Source : OWASP Secure Headers Project
		non noté

À améliorer	**Traceurs avant consentement** La page charge directement ces services, sans attendre le consentement : Meta (Facebook) Pixel (www.facebook.com); Google Analytics (www.googletagmanager.com). Aucune bannière de consentement connue trouvée. > Ne chargez ces services qu'après l'accord du visiteur, via la bannière de consentement (ou un gestionnaire de balises en mode consentement) ; la mesure d'audience peut être exemptée aux conditions de la CNIL. Source : CNIL : règles pour les cookies et autres traceurs (directive ePrivacy, article 5(3))	non noté
Info	**Cookies** Aucun cookie déposé sur la page d'accueil. Source : RFC 6265 (cookies HTTP) et guide MDN sur les cookies — Voir aussi : Guide ANSSI site web PA-009 v2.0 (2021), §5.5.3 · Guide CNIL de la sécurité des données personnelles (2024) : sécuriser les sites web	0 pts
Info	**Referrer-Policy** Absent : les navigateurs appliquent leur politique par défaut (strict-origin-when-cross-origin dans les versions récentes). > Ajoutez « Referrer-Policy: strict-origin-when-cross-origin » (rapporte des points bonus). **Sur Apache :** `Header always set Referrer-Policy "strict-origin-when-cross-origin"` Source : W3C Referrer Policy — Voir aussi : Guide ANSSI site web PA-009 v2.0 (2021), §5.4	0 pts
Info	**Cross-Origin-Resource-Policy** Non défini (facultatif ; rapporte des points bonus s'il est défini). Source : MDN : Cross-Origin-Resource-Policy	0 pts
Info	**Cross-Origin-Opener-Policy** Non défini (facultatif ; rapporte des points bonus s'il est défini). Source : MDN : Cross-Origin-Opener-Policy	0 pts
Info	**Cross-Origin-Embedder-Policy** Non défini (facultatif ; rapporte des points bonus s'il est défini). Source : MDN : Cross-Origin-Embedder-Policy	0 pts
Info	**Permissions-Policy** Absent : aucune restriction d'accès aux fonctions du navigateur (caméra, micro, géolocalisation). > Ajoutez par exemple « Permissions-Policy: camera=(), microphone=(), geolocation=() ». **Sur Apache :** `Header always set Permissions-Policy "camera=(), microphone=(), geolocation=()"` Source : W3C Permissions Policy	non noté

Info	**security.txt (signalement de failles)** Aucun fichier security.txt : une personne qui trouve une faille sur le site ne sait pas qui prévenir. > Publiez /.well-known/security.txt avec au moins un champ Contact et un champ Expires (par exemple généré sur securitytxt.org). Source : RFC 9116 (security.txt)	non noté
Conforme	**Subresource Integrity (intégrité des scripts)** Tous les scripts sont chargés depuis le domaine du site (Subresource Integrity inutile). Source : W3C Subresource Integrity — Voir aussi : Guide ANSSI site web PA-009 v2.0 (2021), R11, R12	0 pts
Conforme	**X-Content-Type-Options** Présent (nosniff). Source : WHATWG Fetch : X-Content-Type-Options — Voir aussi : Guide ANSSI site web PA-009 v2.0 (2021), R6	0 pts

Certificat & TLS

À améliorer	**Versions de TLS acceptées** Le serveur accepte encore d'anciennes versions (TLS 1.0, TLS 1.1), abandonnées depuis 2021 : un attaquant capable d'imposer une ancienne version affaiblit le chiffrement. Versions acceptées : TLS 1.0, TLS 1.1, TLS 1.2, TLS 1.3. > Désactivez TLS 1.0 et 1.1 et n'autorisez que TLS 1.2 et 1.3 (les navigateurs actuels n'utilisent plus les anciennes versions). **Sur Apache :** `SSLProtocol -all +TLSv1.2 +TLSv1.3` Source : RFC 8996 (abandon de TLS 1.0 et 1.1) — Voir aussi : Guide ANSSI TLS v1.2 (2020), R3, R4 · Guide ANSSI site web PA-009 v2.0 (2021), R1 · Guide CNIL de la sécurité des données personnelles (2024) : sécuriser les sites web	-20 pts
À améliorer	**Certificat HTTPS** Le certificat expire dans 20 jours (17/11/2026). > Vérifiez que le renouvellement automatique est en place. Source : Guide TLS de MDN — Voir aussi : Guide ANSSI TLS v1.2 (2020), R8 · Guide CNIL de la sécurité des données personnelles (2024) : sécuriser les sites web	-10 pts
Conforme	**Version du protocole TLS** Connexion établie en TLSv1.3. Source : RFC 8996 (abandon de TLS 1.0 et 1.1) — Voir aussi : Guide ANSSI TLS v1.2 (2020), R3, R4 · Guide ANSSI site web PA-009 v2.0 (2021), R1 · Guide CNIL de la sécurité des données personnelles (2024) : sécuriser les sites web	0 pts
Conforme	**Suites de chiffrement faibles** Aucune suite de chiffrement cassée acceptée (RC4, 3DES, export, sans chiffrement ou sans authentification). Source : RFC 9325 (recommandations pour un usage sûr de TLS)	0 pts
Conforme	**Confidentialité persistante** Tous les échanges de clés acceptés offrent la confidentialité persistante : une clé privée volée ne permettrait pas de déchiffrer le trafic enregistré. Source : RFC 9325 (recommandations pour un usage sûr de TLS)	0 pts
Conforme	**Clé du certificat** Clé suffisamment robuste (RSA 2048 bits). Source : RFC 9325 (recommandations pour un usage sûr de TLS)	0 pts

Protection des emails

À améliorer	**SPF (expéditeurs autorisés)** L'enregistrement SPF se termine par « ?all » (neutre) : il ne protège presque pas. > Passez à « ~all », puis à « -all » une fois vos expéditeurs listés. **Chez OVHcloud :** ajoutez ou modifiez l'enregistrement dans la zone DNS du domaine. Source : RFC 7208 (SPF) — Voir aussi : Guide ANSSI interconnexion à Internet PA-066 v3.0 (2020), R44	-20 pts
À améliorer	**DMARC (politique anti-usurpation)** Politique « none » : DMARC observe mais ne bloque rien. > Après quelques semaines d'analyse des rapports, passez à « quarantine », puis à « reject ». **Chez OVHcloud :** ajoutez ou modifiez l'enregistrement dans la zone DNS du domaine. Source : RFC 7489 (DMARC) — Voir aussi : Guide ANSSI interconnexion à Internet PA-066 v3.0 (2020), R48+	-20 pts
À améliorer	**MTA-STS (livraison chiffrée des emails)** Non défini : les autres serveurs de mail peuvent vous livrer vos emails sans chiffrement si un attaquant perturbe la connexion. > Publiez une politique MTA-STS (d'abord en mode « testing »), ou activez-la dans votre service de messagerie. **Chez OVHcloud :** ajoutez ou modifiez l'enregistrement dans la zone DNS du domaine. Source : RFC 8461 (SMTP MTA Strict Transport Security) — Voir aussi : Guide ANSSI interconnexion à Internet PA-066 v3.0 (2020), §5.3	-5 pts
Info	**DMARC : rapports** Aucune adresse de rapport (rua) : vous ne voyez pas qui envoie des emails en votre nom. > Ajoutez « rua=mailto:... » pour recevoir les rapports agrégés. **Chez OVHcloud :** ajoutez ou modifiez l'enregistrement dans la zone DNS du domaine. Source : RFC 7489 (DMARC) — Voir aussi : Guide ANSSI interconnexion à Internet PA-066 v3.0 (2020), R48+	0 pts
Info	**DKIM (signature des emails)** Aucune clé DKIM trouvée parmi les sélecteurs courants testés (42). Ce n'est pas forcément un problème : le sélecteur peut avoir un autre nom. > Vérifiez dans votre service de messagerie (Google Workspace, Microsoft 365...) que la signature DKIM est activée. Source : RFC 6376 (DKIM) — Voir aussi : Guide ANSSI interconnexion à Internet PA-066 v3.0 (2020), R46+	non noté
Info	**Rapports TLS (TLS-RPT)** Non défini : vous n'êtes pas prévenu quand d'autres serveurs n'arrivent pas à vous livrer vos emails de façon sûre. > Publiez un enregistrement TXT _smtp._tls, par exemple « v=TLSRPTv1; rua=mailto:tls-reports@votre-domaine ». **Chez OVHcloud :** ajoutez ou modifiez l'enregistrement dans la zone DNS du domaine. Source : RFC 8460 (rapports TLS pour SMTP) — Voir aussi : Guide ANSSI interconnexion à Internet PA-066 v3.0 (2020), §5.3	non noté

Info	**DANE (clés des serveurs de mail dans le DNS)** Non utilisé. Facultatif : DANE permet aux expéditeurs de vérifier la clé du serveur de mail grâce à DNSSEC, et certaines administrations l'exigent. > Si le domaine utilise DNSSEC, publiez un enregistrement TLSA pour chaque serveur de mail (_25._tcp.<serveur>), ou demandez-le à votre fournisseur de messagerie. Source : RFC 7672 (DANE pour SMTP) — Voir aussi : Guide ANSSI interconnexion à Internet PA-066 v3.0 (2020), §5.3	non noté
Conforme	**Serveurs de mail (MX)** 2 serveur(s) : mx1.hosting-example.com, mx2.hosting-example.com Source : RFC 7505 (MX nul pour les domaines qui ne reçoivent pas d'email)	0 pts
Conforme	**Chiffrement des emails reçus (STARTTLS)** Tous les serveurs de mail joints proposent le chiffrement (TLSv1.3). Source : RFC 3207 (STARTTLS pour SMTP) — Voir aussi : Guide ANSSI interconnexion à Internet PA-066 v3.0 (2020), R42	0 pts
Conforme	**Certificats des serveurs de mail** Les certificats des serveurs de mail sont valides. Source : RFC 3207 (STARTTLS pour SMTP) — Voir aussi : Guide ANSSI interconnexion à Internet PA-066 v3.0 (2020), R42	0 pts

Domaine & DNS

Critique — **Sous-domaines oubliés (journaux CT)** — -30 pts

4 sous-domaine(s) trouvé(s) dans les journaux Certificate Transparency (crt.sh), dont 3 encore utilisé(s). Ces sous-domaines pointent vers une ressource qui n'existe plus chez un fournisseur où n'importe qui peut la recréer, puis publier du contenu sur votre domaine (prise de contrôle de sous-domaine) : old-shop.bakery-example.com bakery-shop-2019.azurewebsites.net (Azure App Service).

> Supprimez ces enregistrements DNS dès maintenant, ou recréez la ressource chez le fournisseur avant que quelqu'un d'autre ne le fasse.

Source : RFC 9162 (Certificate Transparency) — Voir aussi : Guide ANSSI site web PA-009 v2.0 (2021), R3

À améliorer — **DNSSEC** — -15 pts

Non activé pour bakery-example.com : les réponses DNS ne sont pas signées, un résolveur ne peut donc pas détecter de fausses réponses (qui redirigeraient visiteurs ou emails vers un autre serveur).

> Activez DNSSEC chez votre hébergeur DNS, puis publiez l'enregistrement DS chez votre registrar (souvent une simple option dans son interface).

Chez OVHcloud : activez DNSSEC dans les réglages de la zone DNS.

Source : RFC 4033 (introduction et exigences de la sécurité DNS) — Voir aussi : Guide ANSSI noms de domaine BP-038 v1.3 (2017), R4+ · Guide ANSSI interconnexion à Internet PA-066 v3.0 (2020), R50+

À améliorer — **CAA (autorités de certification autorisées)** — -5 pts

Aucun enregistrement CAA : n'importe quelle autorité de certification peut émettre un certificat pour ce domaine.

> Publiez un enregistrement CAA qui nomme l'autorité que vous utilisez, par exemple 0 issue "letsencrypt.org".

Chez OVHcloud : ajoutez ou modifiez l'enregistrement dans la zone DNS du domaine.

Source : RFC 8659 (autorisation des autorités de certification par DNS)

À améliorer — **Verrou de transfert** — -5 pts

Le domaine n'est pas verrouillé contre les transferts : avec un accès volé à votre compte chez le registrar, il est plus facile de le déplacer ailleurs.

> Activez le verrou de transfert (souvent appelé « registrar lock ») chez votre registrar.

Source : RFC 5731 (statuts d'un domaine, dont l'interdiction de transfert) — Voir aussi : Guide ANSSI noms de domaine BP-038 v1.3 (2017), R1, R3+

Conforme — **Date d'expiration du domaine** — 0 pts

Le domaine bakery-example.com est enregistré jusqu'au 15/05/2027 (199 jours). Registrar : Example Registrar.

Source : RFC 9083 (RDAP, données d'enregistrement des noms de domaine) — Voir aussi : Guide ANSSI noms de domaine BP-038 v1.3 (2017), §4.10

Méthode. Audit passif réalisé par Loïc Tellier à partir d'informations publiques uniquement : enregistrements DNS, certificat présenté par le serveur et page d'accueil. Aucun test d'intrusion n'a été effectué. Notes. La note du site web suit le barème Mozilla HTTP Observatory (pénalités et bonus par en-tête). Les notes certificat, email et DNS suivent le barème propre au projet, fondé sur les normes citées sous chaque point. La note globale est la plus basse des quatre. Limites. Cet audit ne couvre pas les applications du site, les postes de travail ni les comptes utilisateurs. Il donne une vue d'ensemble de l'exposition visible depuis Internet à la date indiquée. Les recommandations de l'ANSSI citées indiquent à quoi se rattache chaque contrôle ; les respecter pleinement dépend aussi de réglages invisibles depuis l'extérieur : ce rapport n'est donc pas une attestation de conformité.